

VERITRUST ANALYTICS

Threat Intelligence Assessment

Financial Services & Credit Reporting

Prepared by: The Cybersecurity Team

Date: September 2026

Table of Contents

Executive Summary.....	3
Introduction.....	4
Our Tooling: OpenCTI and How We Deployed It	5
Why We Used OpenCTI	5
Why We Ran It in the Cloud	5
Deployment and Configuration.....	5
How We Used It in This Assessment	5
Section One: The Sector Threat Landscape	6
Top Threats, Actors and Campaigns.....	7
Commonly Observed Malware and Tools	9
Commonly Observed Techniques (MITRE ATT&CK).....	10
Pattern of Targeting	11
Notable Industry Alerts and Historic Incidents	11
Section Two: The National Threat Landscape, United States	12
Threat One: APT29 / UNC2452 (State-Sponsored Espionage, Russia-Linked)	13
Threat Two: Handala Hack / VOID MANTICORE (Destruction and Data Extortion, Iran-Linked)	15
Section Three: Recently Targeted Victims	17
Section Four: A Politically Motivated Threat Group, APT41	20
Campaigns.....	21
Tools and Malware.....	21
Attack Patterns (MITRE ATT&CK)	22
Indicators of Compromise (Sample).....	23
Publicly Documented Incidents.....	23
Section Five: What This Means for Veritrust.....	25
Potential business impact	25
Section Six: Recommendations	26
How These Recommendations Strengthen Veritrust’s Security Posture	26
Next Steps	27
Scope and Limitations	27
Conclusion	27
The Cybersecurity Team.....	29
Team Contributions	29
Glossary.....	30
Sources	31

Executive Summary

This report takes a look at the cyber threats facing Veritrust Analytics, a credit reporting and financial services company based in the United States. We hold sensitive personal, financial, employment and identity data, which makes us an attractive target for people who want to steal data, commit fraud, disrupt services or demand a ransom.

This research was done in OpenCTI, with AlienVault OTX and MITRE ATT&CK adding detail. No one on the team could run Docker or Kali on their own device, because of limited storage, Macs that did not support virtualization and a tight timeline. So we ran OpenCTI in the cloud and integrated AlienVault OTX into it.

What we found

- **Our sector (Section One).** FIN13, Operation Wocao and Operation Dust Storm go after the same personal data, financial records and admin credentials that we hold. Credential dumping and finance-themed phishing keep showing up.
- **The United States (Section Two).** Two threats are active against US targets: APT29 (UNC2452), a Russia-linked espionage group that is good at supply chain and cloud identity attacks, and Handala Hack (VOID MANTICORE), an Iran-linked group that uses wipers, ransomware and data extortion.
- **Recent victims (Section Three).** ImmobiliareLabs, Leo Platform and Okendo were all supply chain compromises. The attackers poisoned something the victim already trusted, and two of the three were hit by the same worm family.
- **APT41 (Section Four).** A Chinese state-sponsored group that also runs financially motivated operations. In campaign C0017 it compromised at least six US state government networks through vulnerable web applications, took personal data, and in at least two cases came back after remediation.

What it means for Veritrust

The same five routes keep coming up: trusted software and vendors, stolen or abused credentials, internet-facing applications, data theft, extortion and destruction, and phishing. The impact could include regulatory and legal trouble, lost trust from lenders, employers and consumers, service disruption, fraud losses and response costs, and a huge knock-on effects for partner banks and lenders.

Recommendations

We recommend five programs, one for each route: software supply chain security, identity and credential protection, internet-facing application defense, data protection and resilience, and phishing and social engineering defense. They work in layers, with some keeping attackers out, some limiting what they can do once inside and some limiting the damage. Section Six sets out how each program improves our security posture and how we would tell it is working. We also suggest giving each program an owner, holding quarterly threat intelligence briefings, and testing incident response and backup recovery against a destructive, data-leak scenario within the next planning cycle.

The data comes from our OpenCTI instance, where the newest reports run to late June 2026, and attribution for ImmobiliareLabs is still open. The last sections of the report show what each team member contributed.

Introduction

Veritrust Analytics is a data analytics company. We provide credit reporting, identity verification and risk analysis to consumers, lenders, employers and other organizations, which means we hold a lot of sensitive personal, financial, employment and identity information. People rely on that information to make decisions about loans, housing, insurance and jobs. Veritrust is based in the United States, so the national threats covered in Section Two apply to us directly.

That makes Veritrust an attractive target. Threat actors go after this kind of data to steal it, commit fraud, disrupt services or demand a ransom, and an incident could hurt us financially, operationally, legally and in reputation.

For a company like ours, cybersecurity is not a side issue. Clients, partners and regulators trust us with their financial and personal data, and that trust is what the business runs on. Organized criminal groups, and sometimes state-sponsored actors, pay close attention to credit reporting organizations because of what we store.

This report looks at the threats facing our sector. It is not a general survey of cyber risk. We concentrated on the actors, malware and techniques that our threat intelligence platform ties to financial services and credit reporting, and for each finding we explain what it could mean for Veritrust day to day.

After a short note on the tool and how we set it up, the report has six sections: the threats to our sector, the national threat landscape in the United States, recently targeted victims, a politically motivated threat group, what all this means for Veritrust, and our recommendations. The findings come from OpenCTI, with AlienVault OTX and MITRE ATT&CK adding detail. We hope they help the reader see which risks matter most to Veritrust and where to set security priorities.

We wrote this so the reader has enough background to weigh our recommendations and decide where security money and effort should go next. We would be glad to talk through the findings and the proposed fixes in more detail.

Our Tooling: OpenCTI and How We Deployed It

All the findings in this report come from one tool, OpenCTI. Here is how we set it up and why.

Why We Used OpenCTI

OpenCTI is an open-source platform for storing and exploring threat intelligence. It keeps actors, campaigns, malware, techniques, indicators, victims and reports in one connected knowledge base, so we could start from a sector or a country and follow the links to who was targeting it and how.

Why We Ran It in the Cloud

Our first plan was to run OpenCTI on our own machines, using Docker or Kali Linux based on the instruction given. That did not work for the team, as the storage on our systems was not enough, and some devices, such as Macs, did not support the virtualization we needed. In the end no one on the team was able to deploy Docker or Kali locally. The attempts were already eating into our timeframe, so we decided to run OpenCTI in the cloud instead. That took the storage and virtualization problems off our own devices.

Deployment and Configuration

We ran OpenCTI on a virtual server in Amazon Web Services (AWS) and used it through its web interface. Once it was up, we integrated AlienVault OTX, so the platform could bring in OTX's community threat data (pulses and their indicators) alongside the MITRE attack knowledge we used for techniques and groups. The table records the setup.

Item	What we used
Where it ran	In the cloud on AWS, not on our own machines.
Compute	One EC2 instance, type t2.2xlarge (8 vCPU, 32 GiB memory).
Storage	50 GiB General Purpose SSD.
Networking	A VPC and subnet created for the deployment, with a public IP attached to the EC2 instance for public access.
Remote access	An SSH key pair created for secure shell access.
Security groups	Port 8080 open to all addresses (0.0.0.0/0) for access to the OpenCTI dashboard. Port 22 open only from the administrator's source IP for SSH.
Threat data feed	AlienVault OTX, integrated into OpenCTI
Reference knowledge	MITRE ATT&CK techniques and groups, used for technique mapping and group profiles.

How We Used It in This Assessment

- **Section One.** Searches for “financial” and “finance”, then every linked actor, campaign, malware family and report.
- **Section Two.** The United States location entity, to see which intrusion sets target US organizations.
- **Section Three.** Reports sorted newest first, to pick the three most recent named victims.
- **Section Four.** The last-three-months dashboard, to find the most active group, APT41.

Section One: The Sector Threat Landscape

Veritrust is in financial services, so we started by searching OpenCTI for “financial” and “finance”, filtered by entity type. We then went through the sector entities and every actor, campaign, malware family and report linked to them (127 and 21 linked objects respectively at the time of review). What follows are the findings that matter most for a credit reporting organization.

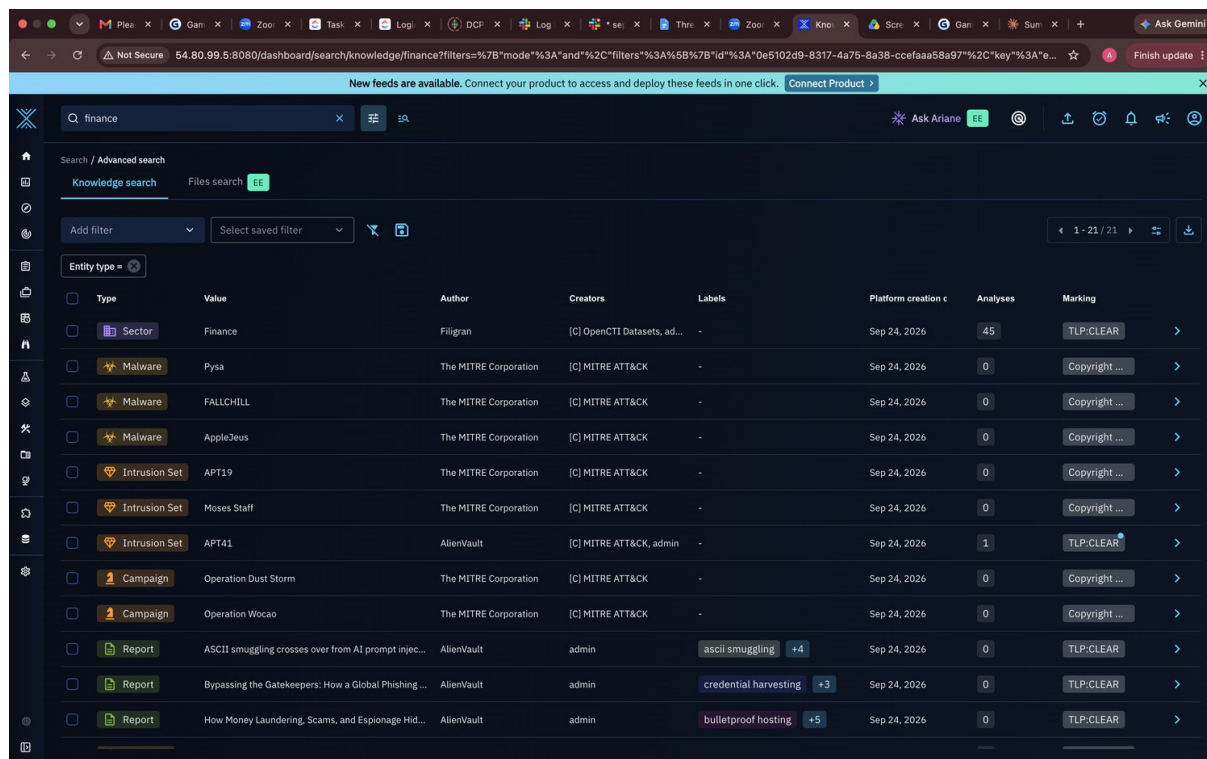


Figure 1. Knowledge search for “finance”: the Finance sector entity (45 linked analyses) with associated malware (Pysa, FALLCHILL, AppleJeus), intrusion sets (APT19, Moses Staff, APT41) and campaigns (Operation Dust Storm, Operation Wocao).

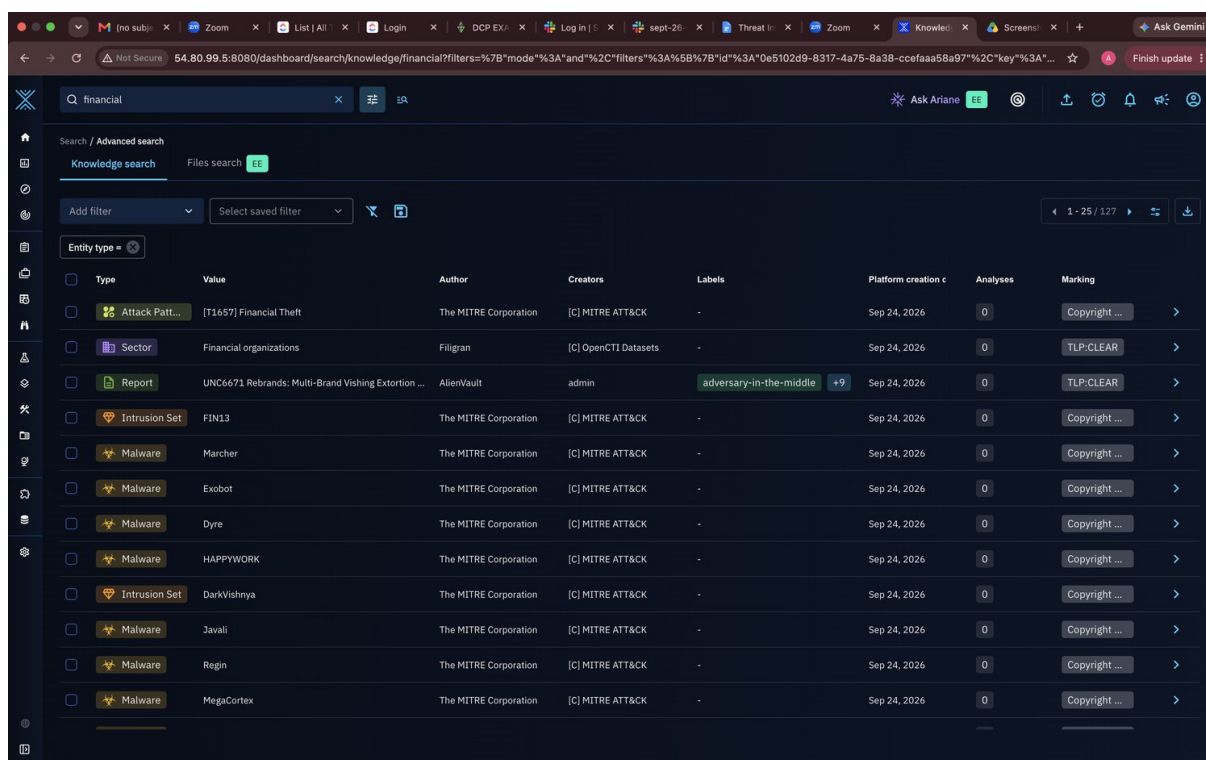


Figure 2. Knowledge search for “financial” (127 results): the Financial organizations sector, the UNC6671 report, the FIN13 intrusion set and related malware.

Top Threats, Actors and Campaigns

FIN13 (Elephant Beetle). A financially motivated group that has been active since at least 2016. It targets financial, retail and hospitality organizations in Mexico and Latin America. FIN13 steals intellectual property, financial data, merger and acquisition information and personal data, which are the same kinds of data we hold on customers and enterprise clients.

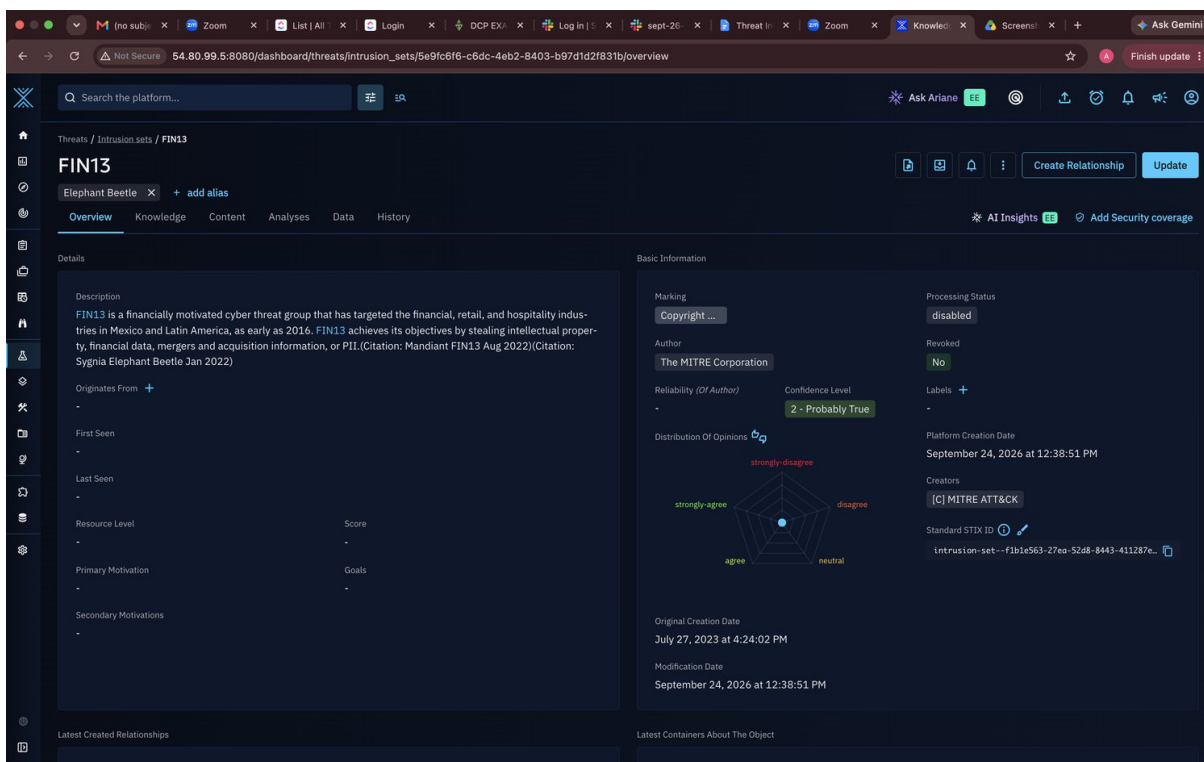


Figure 3. FIN13 (alias Elephant Beetle) overview: description, author (The MITRE Corporation) and confidence level (2, Probably True).

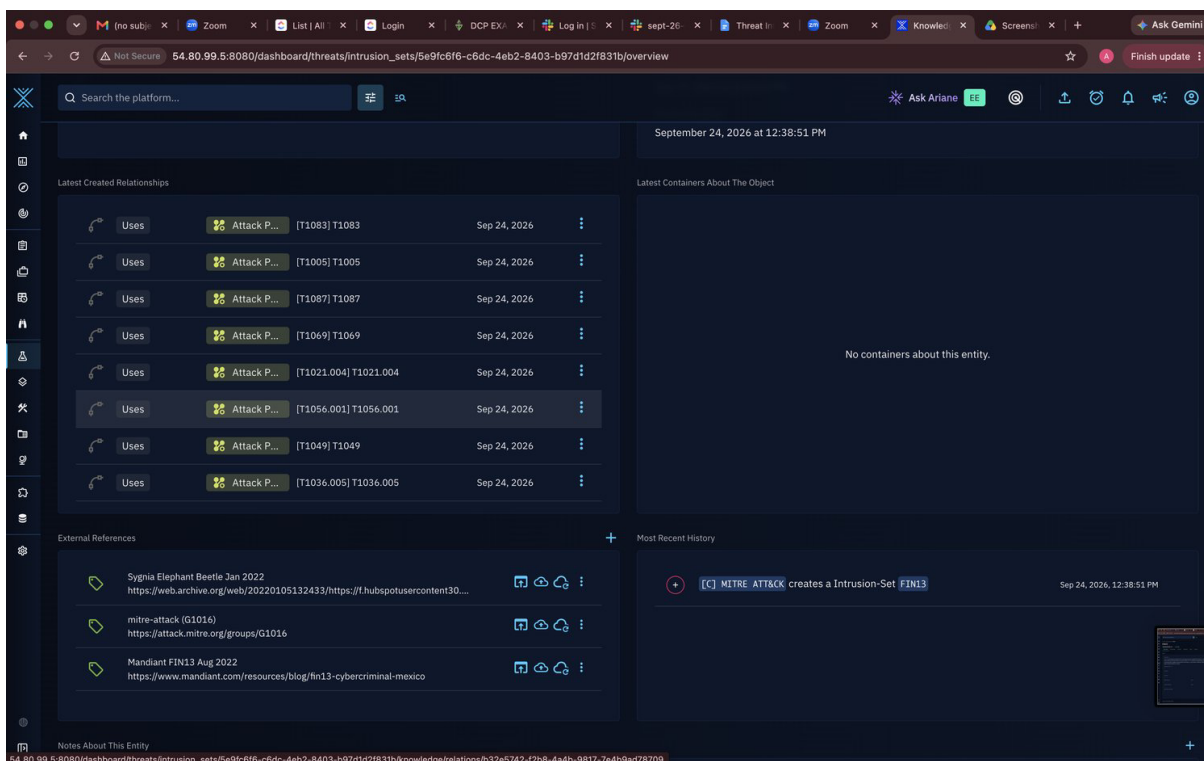


Figure 4. FIN13 relationships (the ATT&CK techniques it uses) and external references (Sygnia, MITRE ATT&CK, Mandiant).

Operation Wocao. A cyber espionage campaign linked to suspected China-based actors. Its victims were in Brazil, China, France, Germany, Italy, Mexico, Portugal, Spain, the United Kingdom and the United States, across government, managed service providers, energy, finance, healthcare, insurance and transportation. Researchers saw tooling overlap with APT20. The actors used the DCSync feature of Mimikatz to pull password

hashes straight from Active Directory, including those of privileged accounts, which can then be used to forge access tickets.

Operation Dust Storm. A long-running espionage campaign. By 2015 it had moved away from government and defense targets and toward companies that support critical infrastructure, including finance, energy, transportation and construction. It also started using Android backdoors around that time, and it relies on file and directory discovery to decide how far to take an infection.

Commonly Observed Malware and Tools

Malware	Linked actor	Technique in OpenCTI	What it does
Pysa	Ransomware operators	T1036.005 Masquerading	In use since October 2018. Disguises malicious programs under legitimate names such as svchost.exe. Targets high-value finance, government and healthcare organizations.
FALLCHILL	Lazarus Group	T1082 System Information Discovery	Remote access tool in use since 2016 against aerospace, telecom and finance. Delivered by other malware or compromised websites. Collects system details and hides its traffic using fake TLS.
AppleJeus	Lazarus Group	T1497.003 Time-based evasion	Downloader first seen in 2018 inside trojanized cryptocurrency apps. Waits before fetching its next stage to avoid sandbox analysis, and has been used to deliver FALLCHILL.

The screenshot shows the OpenCTI interface for the Pysa malware. The main panel displays the relationship between Pysa and the Attack Pattern T1036.005 (Masquerading). The description states: "Pysa has executed a malicious executable by naming it svchost.exe. (Citation: CERT-FR PYSA April 2020)". The start time is April 1, 2020, 1:00:00 AM, and the stop time is April 1, 2020, 1:00:00 AM. The interface also shows a list of indicators and reports related to Pysa.

Report 2 entitie(s)

- The Psychedelic Stealer: When a CAPTCHA Becomes an Installer clipboard +5
- Uncovering a SectorsRAT Variant Embedded in Legitimate Software crypto +4

Indicator 18 entitie(s)

- http://107.175.82.242:9000/willow/psychedelicleve.exe clipboard +5
- https://uasputnik.com/sputnik.html clipboard fake captcha infostealer msi package psychedelic windows run
- https://uasputnik.com/elita.msi clipboard fake captcha infostealer msi package psychedelic windows run
- 38e90affe37342ee36917cdc535fe9bf04589afa8430eb8d1ba1016adcf1878 clipboard +5
- 06f434695f93d7fd11eeff71358ff69ed79d310a66d993bbcc4ff979c117c90 clipboard +5
- 193.178.159.128 clipboard +5
- CC=RU ASN=AS20499 ip communications ltd. clipboard +5
- 107.175.82.242 CC=US ASN=AS36352 colocrossing clipboard fake captcha infostealer msi package psychedelic windows run
- https://bsc-dataseed4.ninico.in.io/ crypto +4
- https://bsc-dataseed4.defbit.io/ crypto +4
- https://bsc-dataseed3.ninico.in.io/ crypto +4
- https://bsc-dataseed3.defbit.io/ crypto +4
- https://bsc-dataseed2.ninico.in.io/ crypto +4

Figure 5. Pysa uses Attack Pattern T1036.005 (Masquerading), with linked reports and indicators.

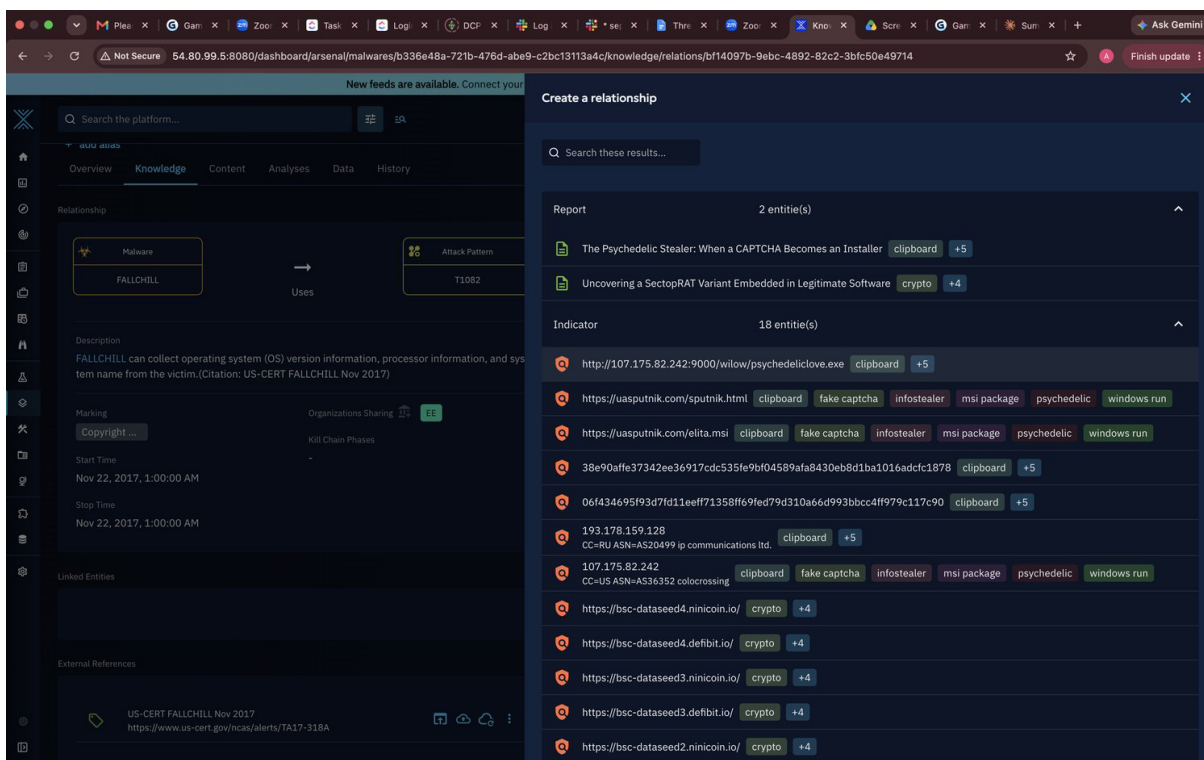


Figure 6. FALLCHILL uses Attack Pattern T1082 (System Information Discovery).

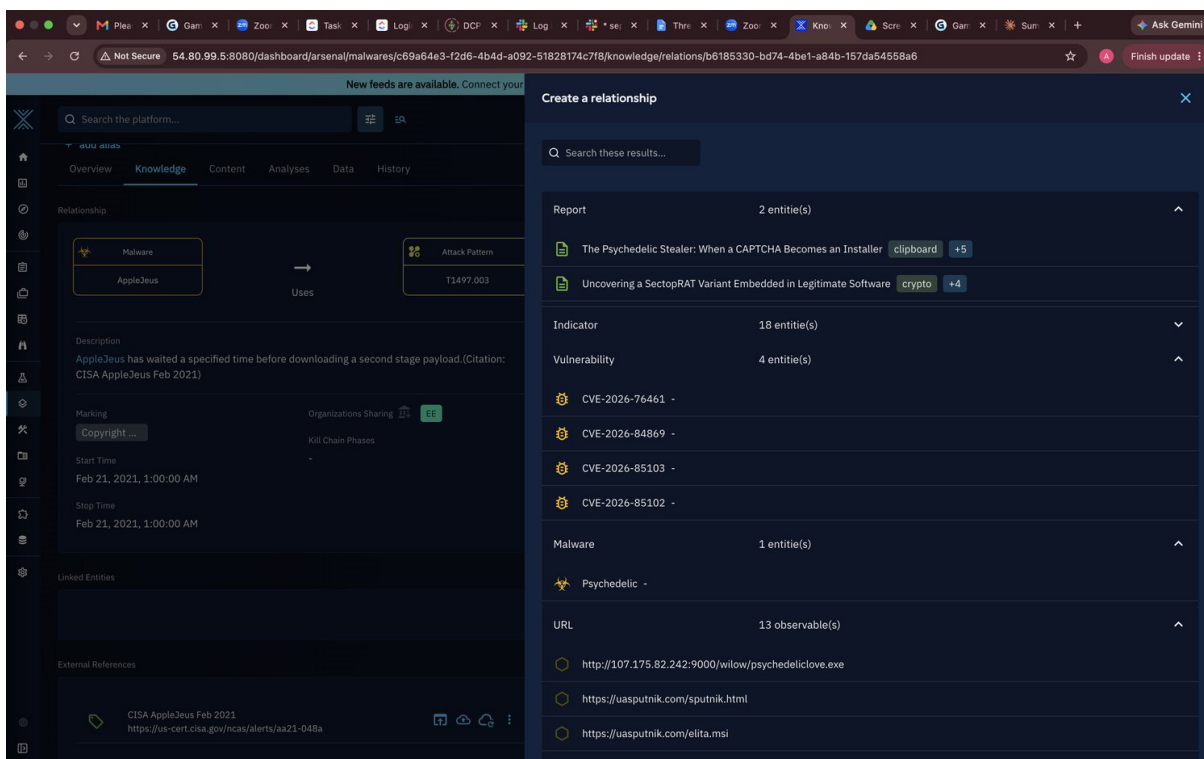


Figure 7. AppleJeuS uses Attack Pattern T1497.003 (time-based evasion), with linked vulnerabilities and URLs.

Commonly Observed Techniques (MITRE ATT&CK)

ID	Technique	Seen with
T1083	File and Directory Discovery	Operation Dust Storm

ID	Technique	Seen with
T1005	Data from Local System	FIN13
T1087	Account Discovery	FIN13
T1069	Permission Groups Discovery	FIN13
T1021.004	Remote Services: SSH	FIN13
T1056.001	Input Capture: Keylogging	FIN13
T1049	System Network Connections Discovery	FIN13
T1036.005	Masquerading: Match Legitimate Name or Location	FIN13, Pysa
T1003.006	OS Credential Dumping: DCSync	Operation Wocao
T1082	System Information Discovery	FALLCHILL
T1497.003	Virtualization/Sandbox Evasion: Time Based	AppleJus

Pattern of Targeting

A recent campaign against the financial sector used huge volumes of finance-themed phishing, mostly business-loan and credit-line lures. The messages came from disposable finance-themed domains and were sent through a legitimate email marketing platform. To get past filters, the attackers hid invisible Unicode characters inside financial keywords, so a message looked normal to the reader but slipped past keyword matching and machine-learning filters. Reported volumes were in the millions of messages per day, and only on weekdays.

Notable Industry Alerts and Historic Incidents

Incident or alert	Type	Relevance to the sector
UNC6671 rebrands	Recent campaign	Vishing and extortion aimed at financial services and enterprise cloud environments.
Operation Wocao	Historic campaign	Espionage that included financial organizations among its victims.
Operation Dust Storm	Historic campaign	Expanded into critical-infrastructure organizations, including finance.
FIN13	Historic activity	Financially motivated intrusions against financial organizations in Latin America.
AppleJus and Lazarus Group	Historic activity	Malware campaigns against finance and other sectors.

What this means for Veritrust. Data theft is the goal in almost every case here. Credential dumping is a proven way to turn one foothold into control of the whole domain, and finance-themed phishing looks a lot like the everyday emails a credit reporting business sends and receives.

Section Two: The National Threat Landscape, United States

Veritrust is headquartered in the United States. Using OpenCTI (AlienVault OTX feed) and MITRE ATT&CK, we picked out the two threats with the most relevant active intrusion set and campaign activity against United States targets: APT29, tracked in OpenCTI as UNC2452, and Handala Hack, tracked by MITRE as VOID MANTICORE.

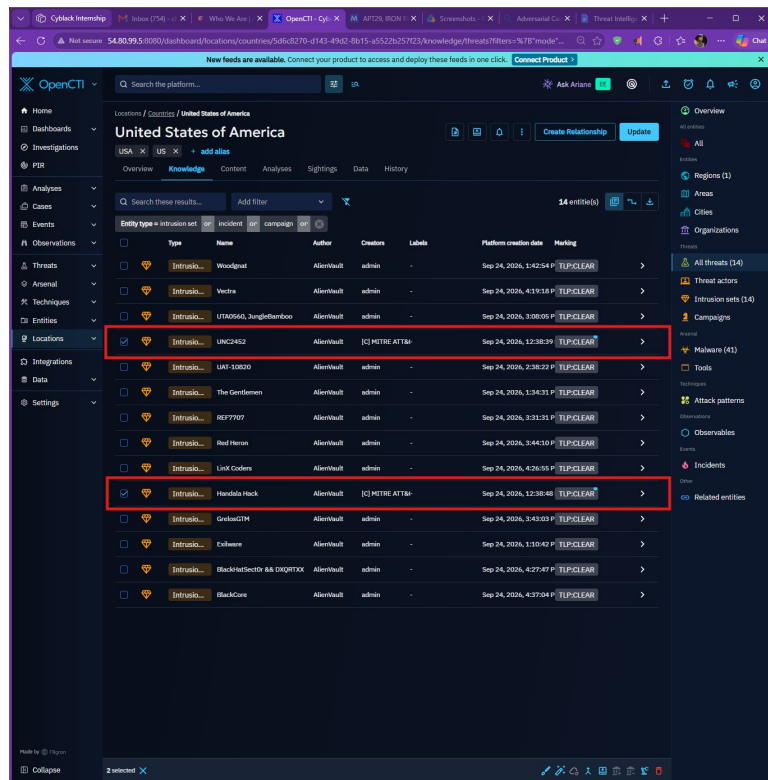


Figure 8. The United States location entity: intrusion sets targeting US organizations, with UNC2452 and Handala Hack highlighted.

Threat One: APT29 / UNC2452 (State-Sponsored Espionage, Russia-Linked)

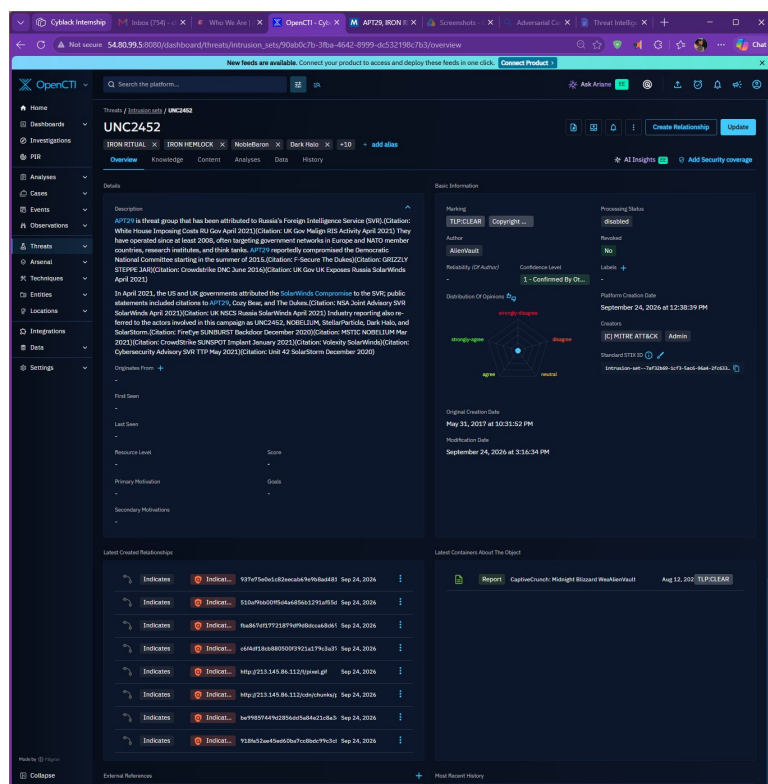


Figure 9. UNC2452 (APT29) intrusion set overview.

Also known as. Cozy Bear, Midnight Blizzard, NOBELIUM and The Dukes.

Attribution and motivation. Russia's Foreign Intelligence Service (SVR). The aim is long-term espionage and intelligence collection.

Behavior. Patient and quiet. It uses software supply chain compromise and spearphishing, and it leans heavily on cloud identity (Azure AD and Microsoft 365), including OAuth application abuse, forged SAML tokens and stolen session cookies. It also uses living-off-the-land tools such as PowerShell and WMI, along with Cobalt Strike.

Campaigns. The SolarWinds Compromise (August 2019 to January 2021) used a trojanized SolarWinds Orion update to deliver the SUNBURST backdoor, and it affected roughly 18,000 organizations, including US federal agencies. Operation Ghost (2013 to 2019) went after foreign ministries and embassies with steganography-based malware (FatDuke, MiniDuke, PolyglotDuke, RegDuke).

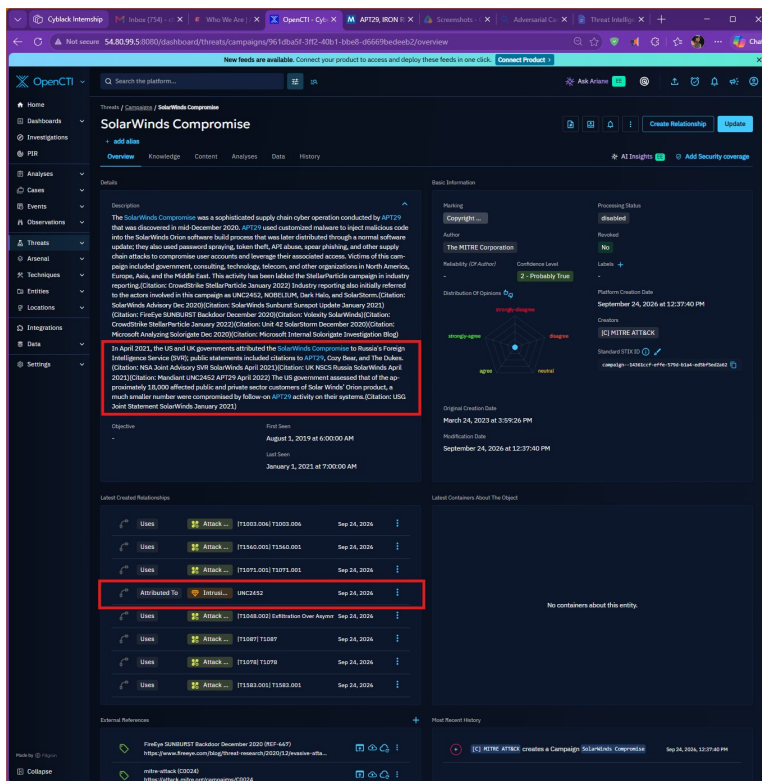


Figure 10. SolarWinds Compromise campaign overview, linked to UNC2452 (APT29).

Indicators. Command-and-control domains made to look like legitimate infrastructure, malicious hosting addresses (for example 213.145.86.112), the code-signed SUNBURST library, and forged SAML authentication tokens.

Relevance to Veritrust. APT29 has shown it can compromise trusted software and cloud identity. That is a direct espionage risk to our back-end systems and customer data stores.

Threat Two: Handala Hack / VOID MANTICORE (Destruction and Data Extortion, Iran-Linked)

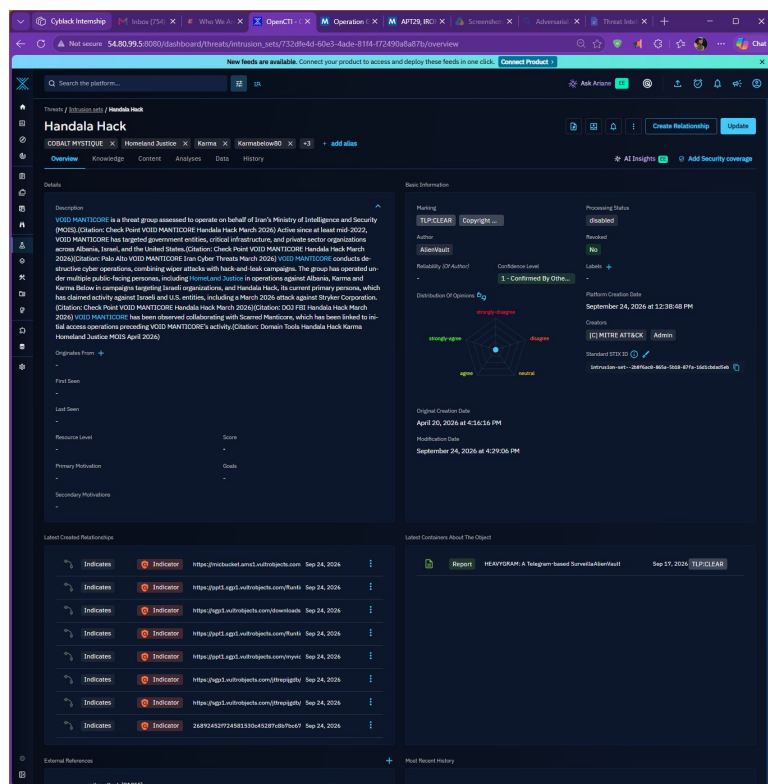


Figure 11. Handala Hack intrusion set overview and linked indicators.

Also known as. COBALT MYSTIQUE, Homeland Justice, Karma and Red Sandstorm.

Attribution and motivation. Iran's Ministry of Intelligence and Security (MOIS). The aim is destructive and disruptive operations mixed with hacktivist-style extortion and hack-and-leak.

Behavior. Gets in by exploiting public-facing applications, credential stuffing and password spraying. It then deploys wipers and ransomware (ROADSWEEP, ZeroCleare, RawDisk) to encrypt or destroy data and make recovery harder, and uses Telegram-based command channels and social media personas to publicize the breaches.

Campaigns. HomeLand Justice (2021 to 2022) was a wiper and ransomware campaign against Albanian government networks. The Handala Hack persona also claimed an attack in March 2026 on Stryker Corporation, a US medical-device company, which suggests it is actively interested in US private-sector targets.

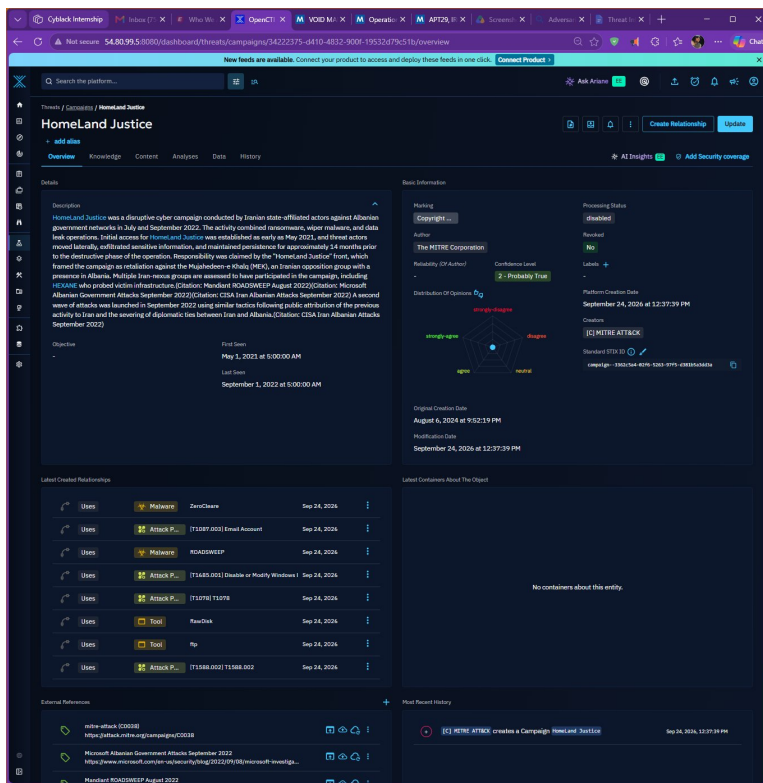


Figure 12. HomeLand Justice campaign overview, linked to Handala Hack / VOID MANTICORE.

Indicators. Web shells (pickers.aspx, error4.aspx, ClientBin.aspx), Telegram bot command channels, typosquatted and rotated domains, and indicators tied to the HEAVYGRAM Telegram-surveillance report in OpenCTI.

Relevance to Veritrust. A breach could disrupt our operations if systems are wiped, and hurt our reputation if the attackers threaten to leak data. Both matter a great deal for a company whose value depends on people trusting its data.

Bottom line. Both actors currently show up as active intrusion sets against US infrastructure in OpenCTI. For APT29 the priorities are vetting our software supply chain and hardening cloud identity. For Handala Hack they are patching public-facing applications and keeping offline, immutable backups.

Section Three: Recently Targeted Victims

We wanted to see how attacks are landing right now, so we looked at the most recent named victims in OpenCTI. We sorted all reports by publication date, newest first. The latest data in our instance runs to late June 2026, so that became our window. We skipped general write-ups that don't name a victim and kept the first three reports that clearly identify an organization that was actually attacked. Where OpenCTI was thin on a detail, such as attribution, we went back to the original public research (Socket, Endor Labs and Zscaler ThreatLabz) instead of guessing.

Name	Type	Author	Creation	Labels	Date	Processing status	Marking
Phishing in the Balkans: Fake Traffic Firms, Real Losses	Threat Report	AlienVault	admin	backdoor, denial	Jul 1, 2026	new	[TIP] CLEAR
Browser-Only Ransomware: From LLM Hallucinations to a Practical Attack Technique	Threat Report	AlienVault	admin	ai-assisted attacks	Jul 1, 2026	new	[TIP] CLEAR
Inside an affiliate panel targeting Microsoft 365	Threat Report	AlienVault	admin	artifacts, business email compromise	Jul 1, 2026	new	[TIP] CLEAR
Not very gentlemanly: Analyzing a zero-day exploit used to disable targets' EDNs	Threat Report	AlienVault	admin	typical, web killer	Jun 30, 2026	new	[TIP] CLEAR
How access to Gmail accounts is gained	Threat Report	AlienVault	admin	credential exploitation	Jun 30, 2026	new	[TIP] CLEAR
Defense Impairment Olympics	Threat Report	AlienVault	admin	credential exploitation	Jun 30, 2026	new	[TIP] CLEAR
A Qipon in the Machine: TaskMaster's Node.js Intrusion Chain	Threat Report	AlienVault	admin	ai development tools, credential theft	Jun 30, 2026	new	[TIP] CLEAR
RAF Abuses TON Blockchain to Target Japan's Hotel Industry	Threat Report	AlienVault	admin	booking.com, credential theft	Jun 29, 2026	new	[TIP] CLEAR
Chromium extension uses AI-related branding to redirect browser search	Threat Report	AlienVault	admin	browser extension, chrome extension	Jun 29, 2026	new	[TIP] CLEAR
From Bing Search to Ransomware: Bumblebee and Adaptive2 Deliver Akira	Threat Report	AlienVault	admin	adaptive2, akira, bumblebee	Jun 29, 2026	new	[TIP] CLEAR
New customer charges for online orders outside the EU	Threat Report	AlienVault	admin	customers, email, fraud	Jun 29, 2026	new	[TIP] CLEAR
The Gentlemen are knocking: custom backdoors and evading tactics	Threat Report	AlienVault	admin	aprilwood, typical, cobalt strike	Jun 29, 2026	new	[TIP] CLEAR
Phishing Campaign PassesFortis - New domain rotation identified associated with the campaign	Threat Report	AlienVault	admin	brand impersonation, chm	Jun 29, 2026	new	[TIP] CLEAR
Miasma Mini Shai-Hulud Hits ImmobiliareLabs npm Packages	Threat Report	AlienVault	admin	backstage plugins, covid compromise	Jun 27, 2026	new	[TIP] CLEAR
Understanding Longflow CVE-2026-55265, and why higher CVEs vulnerabilities aren't always	Threat Report	AlienVault	admin	ai pipeline exploitation	Jun 26, 2026	new	[TIP] CLEAR
Operation DragonBorne: China-Russia Cyber Espionage Campaign Targeting Govt. of India/Me...	Threat Report	AlienVault	admin	china-russia, covid	Jun 26, 2026	new	[TIP] CLEAR
Mini Shai-Hulud Hits LeoPlatform npm Packages and GitHub Actions, Expands to the Go Ecosystem	Threat Report	AlienVault	admin	bin runtime, hedges, legacyplatform	Jun 26, 2026	new	[TIP] CLEAR
Photo ZIP campaign targeting hospitality industry delivers Node.js implant for persistent access	Threat Report	AlienVault	admin	authentication laundering, purenat	Jun 26, 2026	new	[TIP] CLEAR
STOCKSTAY Another Day: The Latest Addition to Turin's Intelligence Gathering Apparatus	Threat Report	AlienVault	admin	diademoback, k5smorpher, kaccus	Jun 26, 2026	new	[TIP] CLEAR
CS-OTA-3562 Targets Southeast Asian Governments and Critical Infrastructure	Threat Report	AlienVault	admin	cs-ota-3562, energy sector	Jun 26, 2026	new	[TIP] CLEAR
From San Pedro to Salinas: How a Chinese Framework "Cloud Uni-App" Powers a Global Sc...	Threat Report	AlienVault	admin	bulletproof hosting	Jun 25, 2026	new	[TIP] CLEAR
Millicent: A RAT Revisited, a Threat Multiplied	Threat Report	AlienVault	admin	atlassian, millicent, net	Jun 25, 2026	new	[TIP] CLEAR

Figure 13. Reports sorted newest first, used to select the three most recent named victims.

	ImmobiliareLabs	Leo Platform	Okendo
Date	June 26, 2026	June 24, 2026	May 14, 2026
Top threat	Miasma Mini Shai-Hulud supply chain worm	Same worm family, larger wave	Poisoned customer-reviews widget
Adversary	Not publicly attributed	TeamPCP (per OpenCTI)	SmartApeSG
Capability	Worm hidden in 22 poisoned npm package versions (8 file hashes in OpenCTI)	Obfuscated worm in all 23 of one maintainer's npm packages, swapped within 6 seconds; spread into Go	Hidden JavaScript with a ClickFix lure delivering a remote access tool and password stealer
Infrastructure	npm registry and the company's own GitHub Actions pipeline	Hijacked maintainer account, npm registry, attacker-run GitHub repositories	Compromised widget script and attacker payload servers
Victim	Internal developer tooling (GitLab link, employee login)	Leo Platform and its downstream users	Okendo and 18,000+ e-commerce stores and their visitors
Kill chain stages	Initial Access, Execution, Credential Access	Initial Access, Execution, Credential Access, Exfiltration	Initial Access, Execution, Defense Evasion, Impact

ImmobiliareLabs. Attackers slipped malicious code into legitimate npm packages that the company itself publishes, specifically the ones that connect its developer tools to GitLab and handle employee login. Twenty-two package versions were affected.

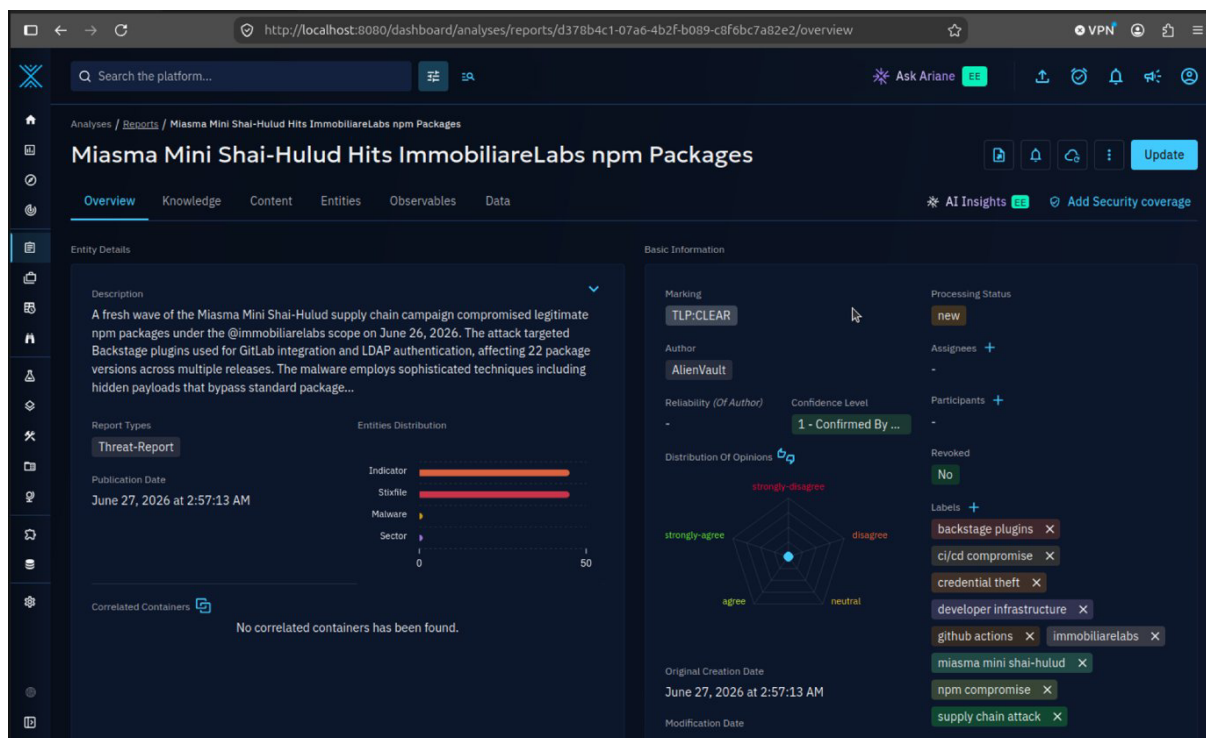


Figure 14. Report: Miasma Mini Shai-Hulud hits ImmobiliareLabs npm packages (June 27, 2026).

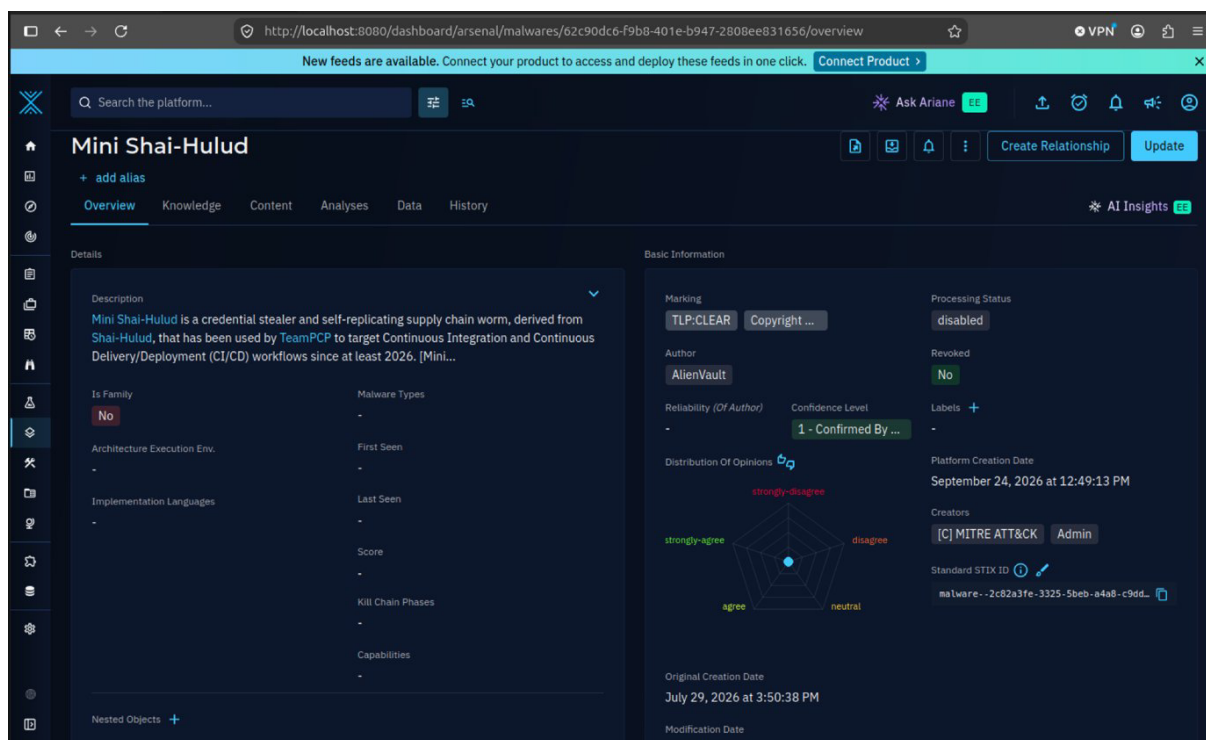


Figure 15. Mini Shai-Hulud malware entity: a credential stealer and self-replicating supply chain worm used by TeamPCP.

Leo Platform. All 23 of one maintainer's packages were swapped for poisoned versions within a six-second window. The hidden code stole cloud logins, password manager data and other secrets, and sent them out through attacker-controlled GitHub accounts.

Okendo. SmartApeSG injected code into a reviews widget used by more than 18,000 stores. The code stayed hidden until the right conditions were met, then tricked visitors into running a command themselves, a technique known as ClickFix.

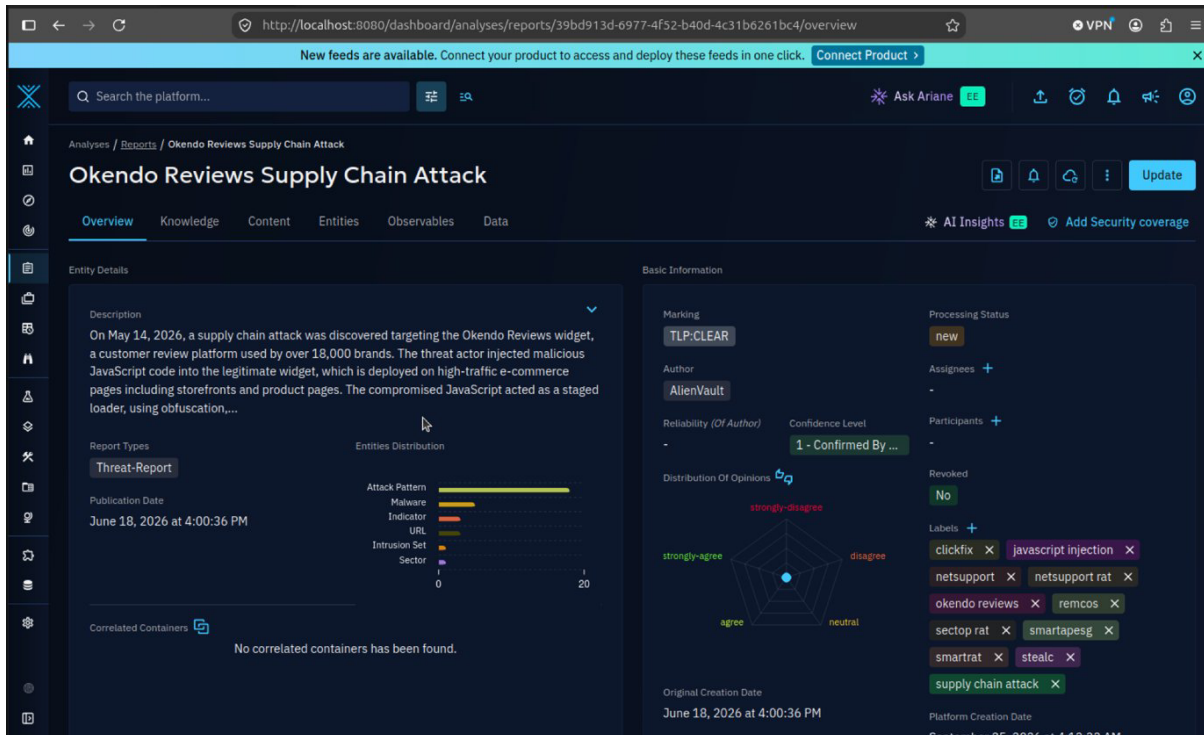


Figure 16. Report: Okendo Reviews supply chain attack (published June 18, 2026).

What ties them together. All three were supply chain compromises. The attacker did not break into the victim directly. Instead they poisoned something the victim or its customers already trusted, either a software package or a piece of embedded website code. Two of the three were hit by the same worm family at different points in its spread, so this looks like one active campaign and not three unrelated incidents.

Relevance to Veritrust. We build on third-party software and embed third-party code. A poisoned dependency would reach us through a channel we already trust, which is why supply chain vetting is one of the priorities in Section Six.

Section Four: A Politically Motivated Threat Group, APT41

OpenCTI's dashboard for the last three months ranks APT41 third among the most active threats. It is the most recent politically driven group with high-profile activity in our data, so we profiled it in detail.

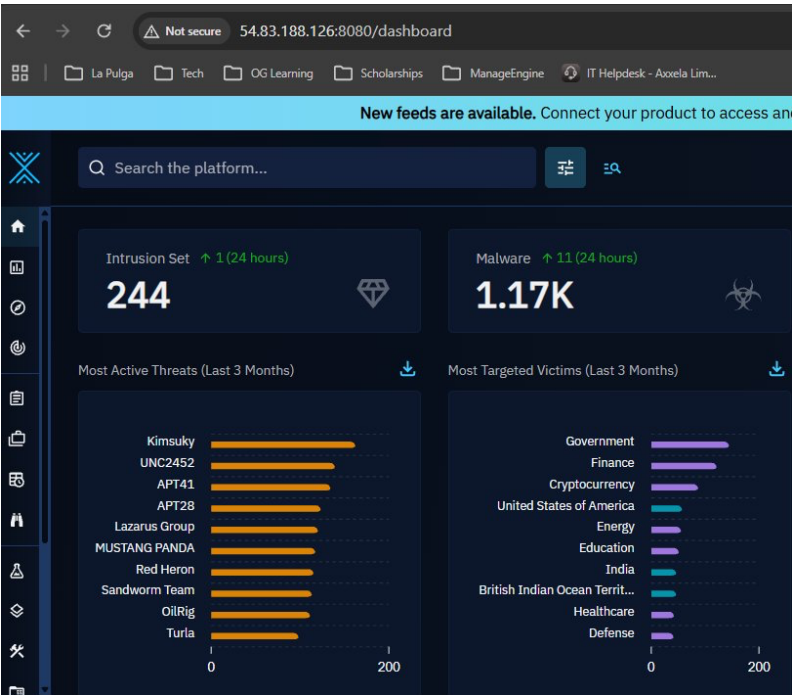


Figure 17. OpenCTI dashboard, last three months. UNC2452 ranks second and APT41 third among most active threats; Finance ranks second among most targeted victims.

Profile	
Aliases	Wicked Panda, Brass Typhoon, BARIUM (partial overlap with Winnti Group)
Attribution	Chinese state-sponsored espionage group that also runs financially motivated operations
Motivation	State espionage and financial gain
Active since	At least 2012
Targets	Healthcare, telecom, technology, finance, education, retail and video games, across 14 countries

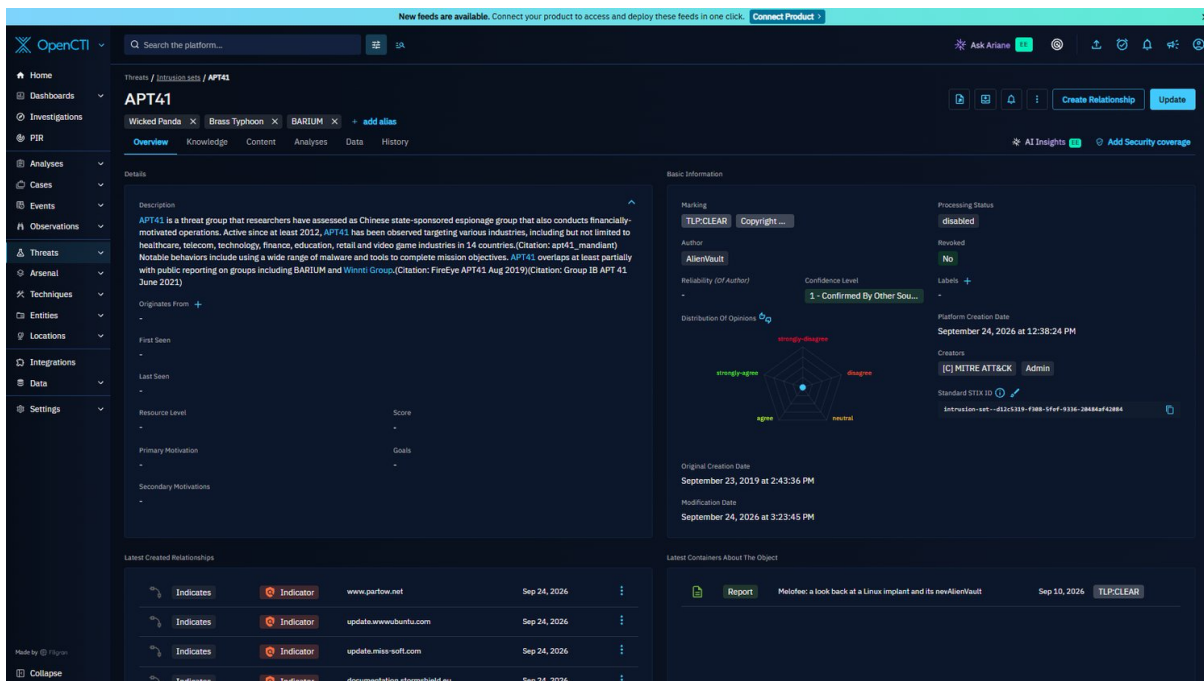


Figure 18. APT41 intrusion set overview (aliases Wicked Panda, Brass Typhoon, BARIUM).

Campaigns

C0017 (May 2021 to February 2022). APT41 compromised at least six US state government networks by exploiting vulnerable internet-facing web applications. The group adapted quickly, using both publicly disclosed and zero-day vulnerabilities to get in, and in at least two cases it came back after the victim had remediated. The goal is unknown, but APT41 was seen taking personal data.

APT41 DUST (2023 to July 2024). Aimed at entities in Europe, Asia and the Middle East, in sectors such as shipping, logistics and media, to gather information. It used previously seen malware such as DUSTPAN together with newly observed tools such as DUSTTRAP.

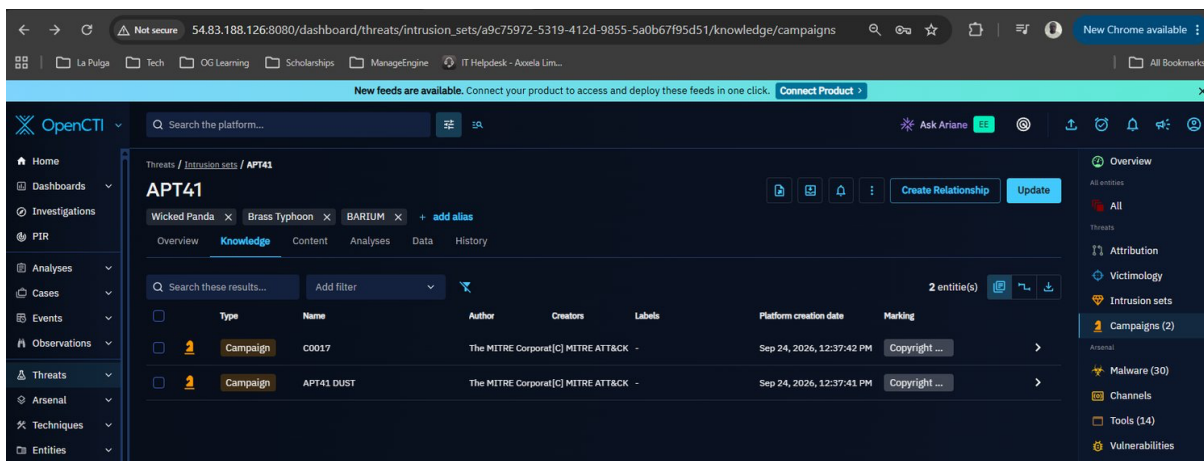


Figure 19. APT41 campaigns: C0017 and APT41 DUST.

Tools and Malware

Tools. sqlmap, pwddump, PowerSploit, netstat, dsquery, certutil, BITSAdmin, Mimikatz and ipconfig.

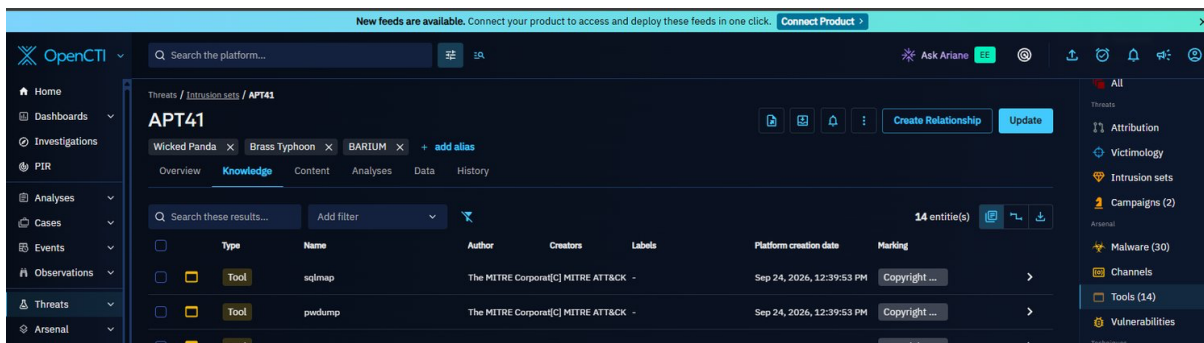


Figure 20. Tools linked to APT41, including sqlmap and pwdump.

Malware	Description	ATT&CK techniques
DUSTPAN	In-memory dropper written in C/C++, used since 2021. Decrypts and runs an embedded payload and can inject it into another process.	T1055.002 Process Injection T1543.003 Windows Service T1027 Obfuscated Files or Information T1140 Deobfuscate/Decode Files
DUSTTRAP	Multi-stage plugin framework with several components, associated with APT41 operations.	T1135 Network Share Discovery T1105 Ingress Tool Transfer T1654 Log Enumeration
Reptile	Open-source Linux rootkit with several components that provides backdoor access.	T1041 Exfiltration Over C2 Channel T1543.002 Systemd Service

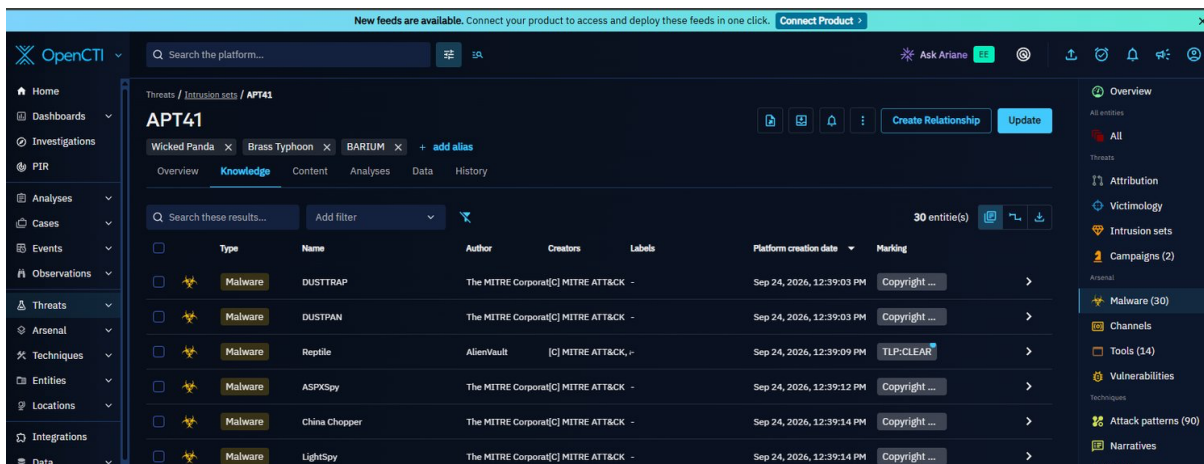


Figure 21. Malware linked to APT41, including DUSTTRAP, DUSTPAN and Reptile.

Attack Patterns (MITRE ATT&CK)

Kill chain phase	Example techniques seen
Reconnaissance	Search Closed Sources (threat intelligence vendors, purchased technical data); Search Open Websites and Domains
Resource Development	Develop Capabilities (T1587.001); Generate Content such as phishing lures, fabricated job postings and decoy documents
Initial Access	Exploit Public-Facing Application (T1190); Replication Through Removable Media (T1091)
Execution	BITS Jobs (Windows Background Intelligent Transfer Service); Scheduled Task/Job (T1053)
Persistence	Boot or Logon Initialization Scripts, including startup items and RC script changes (T1037.004)

Kill chain phase	Example techniques seen
Privilege Escalation	Escape to Host; Process Injection (T1055)
Defense Evasion	Disable or Modify Tools; BITS Jobs; Debugger Evasion
Credential Access	Exploitation for Credential Access; Forced Authentication; Forge Web Credentials; OS Credential Dumping (T1003)
Command and Control	Proxy (T1090)
Exfiltration	Data Transfer Size Limits (T1030); Exfiltration Over C2 Channel (T1041)

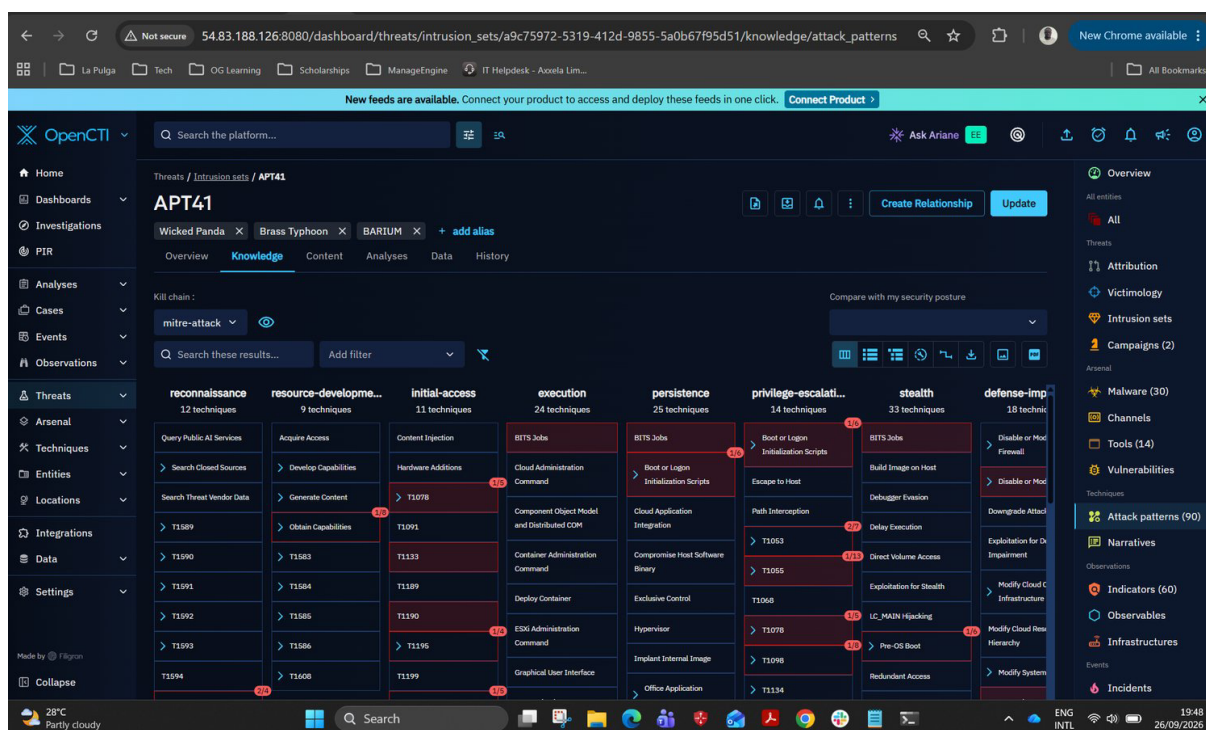


Figure 22. APT41 attack patterns mapped to the kill chain.

Indicators of Compromise (Sample)

Type	Examples
URLs and domains	http://windefender.net:443, documentation.stormshield.eu, microupdate.top, amzaonaws.org, update.miss-soft.com, http://windowsupdate.us:80, update.wwwubuntu.com,
IP addresses	103.215.216.116, 103.215.216.117, 103.87.9.148, 103.215.216.181
File hashes (SHA-256)	0c1666b274ddb44dd5c7a11f03c8c041f6bccf0c7dae924626ef9d15b1cc41d5129349a221e6efcc9a047efdfd81197f796fcf38877344f17f85651b21e33427

Publicly Documented Incidents

Telecom intrusions. Public reporting links APT41 (BARIUM) activity to attacks on US telecom providers using a kernel-level backdoor. The data taken included call metadata and internal communications. Some reporting notes overlap with the Salt Typhoon cluster.

US trade official phishing (2025). A targeted spear-phishing campaign was disguised as an email from a US Representative about trade talks with Beijing. The attachment dropped data-harvesting malware and was aimed at law firms, government agencies and trade groups.

African government IT provider (2025). APT41 breached a government IT services provider in Southern Africa and used custom data-stealing tools (including Pillager and Checkout) to take credentials, source code and government communications.

Relevance to Veritrust. C0017 shows APT41 exploiting internet-facing web applications and taking personal data, which is exactly the kind of asset and exposure we have. It also tends to return after remediation, so fixing a weakness is not enough. We also have to confirm the attacker is really gone.

Section Five: What This Means for Veritrust

Reading the four analytical sections together, we see five routes into organizations like ours that keep coming up. The table below links each route to the evidence and to our own exposure.

Route	Where we saw it	Our exposure
Trusted software and vendors	APT29 and SolarWinds; the Miasma/Shai-Hulud worm at ImmobiliareLabs and Leo Platform; Okendo widget	Third-party packages, build pipelines and embedded scripts we depend on
Stolen or abused credentials	APT29 cloud identity abuse; Wocao DCSync; APT41 Mimikatz and pwdump; FIN13 keylogging	Active Directory, cloud identity and privileged accounts
Internet-facing applications	Handala Hack; APT41 campaign C0017	Consumer and dispute portals and other public web applications
Data theft, extortion and destruction	FIN13; Handala Hack wipers and leaks; APT41 personal data theft	Credit, identity and financial records, and the systems that serve them
Phishing and social engineering	UNC6671 finance-themed lures; ClickFix at Okendo; 2025 spear-phishing by APT41	Staff handling loan and credit communications, and customers

Potential business impact

- Regulatory and legal trouble if consumer personal and credit data is breached.
- Lost trust from lenders, employers and consumers if data is stolen, leaked or altered.
- Service disruption if ransomware or wipers hit the systems behind credit reporting and identity verification.
- Fraud losses from stolen identity data, plus the cost of response, recovery and possible litigation.
- Knock-on effects for partner banks and lenders who rely on our data for their own decisions.

Section Six: Recommendations

We recommend five priority programs, each one aimed at one of the routes in Section Five.

Priority program	Recommended actions	Threats addressed
1. Software supply chain security	Vet and pin third-party packages and embedded scripts. Restrict and rotate secrets in build pipelines. Alert on unexpected package changes. Review vendor and widget dependencies.	APT29; Shai-Hulud worm victims; Okendo
2. Identity and credential protection	Enforce multi-factor authentication and harden cloud identity. Limit privileged accounts and directory replication rights. Monitor for credential dumping tools such as Mimikatz.	APT29; Wocao; APT41; FIN13
3. Internet-facing application defense	Keep an inventory of public applications, patch quickly, and verify that remediation removed the attacker's access. Add web application protection and logging.	Handala Hack; APT41 (C0017)
4. Data protection and resilience	Segment systems and minimize stored personal data. Watch for unusual data movement. Keep offline, immutable backups and test recovery regularly.	FIN13; Handala Hack; APT41
5. Phishing and social engineering defense	Strengthen email filtering, including for hidden-character obfuscation. Train staff who handle credit and loan communications. Warn users about lures that ask them to run commands.	UNC6671; SmartApeSG; APT41

How These Recommendations Strengthen Veritrust's Security Posture

A list of actions only helps if we can say what changes once they are in place. The table below takes each program and sets out the weakness we have today, how the program improves our security posture, and how we would tell that it is working.

Program	Weakness today	How it improves our security posture	How we would know it is working
1. Software supply chain security	We depend on third-party packages, build pipelines and embedded scripts, so a poisoned update would arrive through a source we trust.	Vetting and pinning mean a bad update no longer flows in automatically. Restricted, rotated pipeline secrets limit what a poisoned package can steal, and alerts on unexpected package changes shorten the time between compromise and detection.	Third-party packages and embedded scripts are inventoried and pinned, unexpected changes raise an alert, and pipeline secrets are rotated on a schedule.
2. Identity and credential protection	Active Directory, cloud identity and privileged accounts are what APT29, Wocao, APT41 and FIN13 go after, and stolen credentials work quietly.	Multi-factor authentication and hardened cloud identity mean a stolen password is no longer enough. Fewer privileged accounts and tighter replication rights limit what one foothold can reach and make DCSync-style theft harder. Monitoring for tools such as Mimikatz gives early warning.	MFA covers staff and admin accounts, the list of privileged accounts gets shorter, and credential-dumping alerts have been tested.
3. Internet-facing application defense	Our consumer and dispute portals and other public web applications are the kind of target Handala Hack and APT41 (C0017) exploited.	An inventory shows what is exposed, quick patching closes known weaknesses before attackers use them, and web application protection and logging help block and spot attempts. Checking that remediation removed access deals with APT41 coming back.	There is a full inventory of public applications, patches are applied quickly after release, and every fix is followed by a check that the attacker is gone.

Program	Weakness today	How it improves our security posture	How we would know it is working
4. Data protection and resilience	Credit, identity and financial records, and the systems that serve them, are what FIN13, Handala Hack and APT41 aim at.	Segmentation and less stored personal data limit how much can be taken at once. Watching for unusual data movement helps catch theft in progress. Offline, immutable backups mean a wiper or ransomware attack does not have to turn into a long outage.	Less personal data is stored, unusual data movement raises an alert, and backup recovery tests succeed.
5. Phishing and social engineering defense	Staff who handle loan and credit communications, and our customers, receive the kind of lures seen with UNC6671, ClickFix at Okendo and the 2025 APT41 spear-phishing.	Better filtering, including for hidden-character tricks, stops more lures reaching inboxes. Training helps staff who handle credit and loan mail spot what filters miss, and warnings about lures that ask users to run commands address ClickFix.	Staff report suspicious emails, and filter tests that include hidden-character samples pass.

Put together, the programs work in layers. Supply chain and application controls try to keep attackers out, identity controls limit what they can do if they get in, data protection and backups limit the damage, and phishing defense covers the human route that the other controls cannot fully close. No single program covers everything, but each one answers a route that the evidence shows is being used against organizations like ours.

Next Steps

- Adopt the five programs above and give each one an owner.
- Hold a threat intelligence briefing every quarter so we can check progress against the threats in this report.
- Test incident response and backup recovery against a destructive, data-leak scenario within the next planning cycle.

Scope and Limitations

This assessment reflects the data in our OpenCTI instance, where the newest reports run to late June 2026. Some entities, such as FIN13, have blank fields for first seen, last seen and resource level, which limits how much operational detail we can give. Public research usually records only what researchers could observe, such as how the malicious code got in and what it took, so our victim analysis does not cover every kill chain stage (Reconnaissance, Persistence and Lateral Movement do not appear in any of the three cases). Where OpenCTI lacked a detail, we used the original public research, which is listed under Sources at the end of this report. Attribution for ImmobiliareLabs is still open. Because we ran OpenCTI in the cloud with the AlienVault OTX feed integrated, our view is limited to what that one instance held.

Conclusion

Looking back over the four analytical sections, a few things stand out. Our own sector is already a leading target. Criminal groups like FIN13, and espionage campaigns like Operation Wocao and Operation Dust Storm, go after the same personal data, financial records and administrator credentials that our business is built on. They get to it with masquerading malware, credential dumping and finance-themed phishing.

At national level, two very different threats can reach a US-based company like ours. APT29 is patient and well resourced, and will compromise trusted software and cloud identity to stay quietly inside a network for months or years. Handala Hack is the opposite: fast and destructive, willing to pair wipers with public data-leak extortion to pile on pressure. Between them they put both the confidentiality of our data and the availability of our services at risk.

The victim review in Section Three shows these risks are real and recent. None of ImmobiliareLabs, Leo Platform or Okendo was breached by an attack on its own perimeter. Each was hit through something it or its customers already trusted: a software package, a maintainer account or a piece of embedded website code. For us, this is the clearest sign that supply chain trust has to be treated as a main attack surface and not an afterthought to perimeter defense.

APT41, in Section Four, adds another angle. It mixes state espionage with financially motivated operations, has taken personal data from government networks through vulnerable public-facing applications, and has returned to victims when the original access was not fully removed. That mix of motives, methods and persistence makes it one of the harder threats in this report to close out.

The pattern is the same across all four sections. The actors that matter to Veritrust rarely need anything new. They take advantage of trust: in the software we run, in the credentials our people and systems use, in the public applications our customers rely on, and in the everyday communications our business sends and receives. There is some good news in that. Our priorities are fairly clear rather than open-ended, and the five programs in Section Six are built around exactly these points.

We recommend adopting the programs, giving each one a clear owner, and reviewing progress every quarter against the threats described here. We believe steady, targeted investment in these five areas will noticeably reduce Veritrust's exposure to the threats most likely to affect us.

The Cybersecurity Team

The following members of the Veritrust Analytics Cybersecurity Team worked on this assessment.

Habeeb Aliyy Oluwapelumi

Chukwu PraiseGod

Odewade Adewunmi Adesuwa

Ayomide Popoola

Temiloluwa Akinbile

Roland Nii Ayi Aryee

Jubril Edun

Tshirando Mpho Peter

Dauda Sonia

Team Contributions

We split the work into four tasks. Each task covers one of the four analytical sections, and each pair or group researched its section in OpenCTI. The table shows who did what.

Area of work	Team members	Contribution
Task 1: Sector threat landscape (Section One)	Adesuwa and Habeeb	Research for Section One.
Task 2: National threat landscape, United States (Section Two)	PraiseGod and Temiloluwa	Research for Section Two.
Task 3: Recently targeted victims (Section Three)	Ayomide and Sonia	Research for Section Three.
Task 4: APT41 (Section Four)	Jubril, Roland and Tshirando	Research for Section Four.
Collation of the four tasks	Everyone	The whole team helped bring the four tasks together into one assessment.
The report	Adesuwa, with support from the team	Adesuwa worked on the report. The rest of the team supported by making corrections and adding their contributions.
The presentation slides	Temiloluwa and PraiseGod	Prepared the presentation slides.

Glossary

Term	Meaning
APT (Advanced Persistent Threat)	A well-resourced threat actor, usually state-sponsored, that maintains long-term, targeted access to a victim's network.
ATT&CK	MITRE's public framework of adversary tactics and techniques, used throughout this report to classify how threat actors operate.
C2 / Command and Control	The infrastructure an attacker uses to communicate with and control compromised systems.
ClickFix	A social engineering technique that tricks a website visitor into copying and running a malicious command themselves, often disguised as a fix for a fake error.
CVE	Common Vulnerabilities and Exposures: a public identifier for a specific, known software vulnerability.
DCSync	A credential-theft technique that abuses Active Directory's replication feature to pull password data, including from privileged accounts, without needing direct access to a domain controller.
IOC (Indicator of Compromise)	A technical artifact, such as a file hash, domain or IP address, that can be used to detect a specific threat.
MFA (Multi-factor authentication)	A login method that requires more than one form of verification, reducing the impact of a stolen password.
MOIS	Iran's Ministry of Intelligence and Security, the state body linked to the Handala Hack persona in Section Two.
npm	Node Package Manager, the software registry developers use to publish and install JavaScript packages; a target of the supply chain attacks in Section Three.
OTX (Open Threat Exchange)	AlienVault's open threat intelligence sharing platform, used in this assessment to enrich OpenCTI data.
PII (Personally Identifiable Information)	Information that can identify a specific individual, such as a name, identity number or financial record.
RAT (Remote Access Tool / Trojan)	Malware that gives an attacker remote control of an infected system.
Supply chain attack	An attack that compromises a trusted third-party product, package or service in order to reach its downstream users or customers.
SVR	Russia's Foreign Intelligence Service, the state body linked to APT29 / UNC2452 in Section Two.
TTP (Tactics, Techniques and Procedures)	The patterns of behavior a threat actor consistently uses to plan and carry out an attack.
Wiper	Malware designed to destroy or permanently corrupt data, rather than steal it, typically for disruptive or destructive effect.
Zero-day	A vulnerability that is exploited by an attacker before the vendor has released a fix for it.

Sources

Primary sources (OpenCTI and linked references)

- OpenCTI threat intelligence platform, enriched with AlienVault OTX and MITRE ATT&CK.
- MITRE ATT&CK: Group G1016 (FIN13), Group G0016 (APT29), Group G1055 (VOID MANTICORE / Handala Hack).
- Mandiant, “FIN13” (August 2022); Sygnia, “Elephant Beetle” (January 2022).
- Cylance, “Dust Storm”; FoxIT, “Wocao” (December 2019).
- CERT-FR, “PYSA” (April 2020); US-CERT, “FALLCHILL” (November 2017); CISA, “AppleJeuS” (February 2021).

Supplementary public research (used to fill gaps in OpenCTI)

- Socket, Endor Labs and Zscaler ThreatLabz, original research on the Shai-Hulud worm family and the Okendo compromise (Section Three).
- Obsidian Security, “APT41 (BARIUM) targets telecom providers via kernel-level backdoor espionage campaign”.
- The Hacker News, “China-linked APT41 hackers target US” (September 2025).
- Dark Reading, “China-backed APT41 attack Africa”.
- Stryker Corporation, public company profile (context for the Handala Hack claim in Section Two).